ARTICLE | Article in Press

# Graph-based ransomware propagation modelling and early interception in enterprise networks using dynamic attack surface analysis

**Noora Al Khater**

Received: 23 June 2026 / Accepted: 5 October 2026
© The Author(s) 2026

**Abstract**

Ransomware incidents consistently bypass endpoint detection due to their rapid lateral movement through shared drives and remote services before detonating encryption payloads. Existing detection systems react to encryption activity rather than intercepting propagation. This study models enterprise network topology as a dynamic knowledge graph where node attributes represent device vulnerability scores and edge weights encode lateral-movement probability based on historical authentication logs. A graph attention network (GAT) trained on historical ransomware campaigns predicts high-risk propagation paths in real time, enabling proactive isolation of vulnerable nodes before encryption initiates. A simulation environment built on MITRE ATT&CK ransomware scenarios validates that the proposed interception strategy reduces the mean encrypted file value by 85% compared to endpoint-only detection (median reduction 98%, reflecting a heavy-tailed outcome distribution we characterise in full), even when encryption begins on the first affected host. We further report three results obtained for this extended study. First, the GAT already achieves a 76.2% reduction when trained on a single enterprise network and reaches 89.6% with four, after which it plateaus, indicating the learned propagation cues are not network-specific. Second, and most importantly for an adversarial domain, we introduce and evaluate an abstract "patient" attacker that delays visible encryption to deny the defender its primary dynamic signal: at short silent dwell the proposed defense retains a large advantage, but as the silent dwell grows all detonation-reactive defenses, including ours, converge toward the no-defense outcome, exposing a genuine and previously uncharacterised limitation of detection-triggered interception that we discuss together with complementary mitigations. Third, a GCN baseline slightly outperforms the GAT on interception (89% versus 85%) and an ensemble of the two performs best (91%), confirming that the gains come from the graph formulation and the isolation policy rather than from the attention mechanism itself. The model runs entirely on-premise with no dependence on external threat feeds. We position the contribution deliberately: rather than a new graph-neural-network primitive, it is a problem formulation (early interception as hidden-front prediction on a dynamic enterprise graph), a containment-aware isolation policy with proved structural guarantees, and, most importantly for an adversarial domain, a characterisation of when detonation-triggered defence works and when it provably fails against an adaptive, patient adversary. Ransomware propagation throughout is represented as an abstract probabilistic contagion on a graph.

This Article in Press is shared early to give you faster access to new research. It is citable and carries a permanent DOI. The final edited version will replace it automatically.



https://doi.org/10.1038/s41598-026-75165-0

Published online: 13 October 2026

scientific reports

## Introduction

Ransomware has become one of the most damaging classes of cyber-attack against organisations, hospitals, and critical infrastructure. A defining feature of modern ransomware is that the encryption event the moment files become unusable is the *end* of the attack, not its beginning. Before any payload detonates, the adversary has typically gained an initial foothold and moved laterally across the network, compromising additional hosts through shared drives, remote-administration services, and reused credentials, often reaching file servers and domain controllers that concentrate the organisation's most valuable data[1,2]. By the time endpoint detection observes encryption activity on one machine, the infection has frequently already seeded a dozen others, and isolating the visibly affected host does little to stop the remaining silent footholds from encrypting in turn.

This temporal structure exposes a fundamental limitation of endpoint-centric defence: it is *reactive*. Endpoint detection and response tools are triggered by the behavioural signature of encryption (mass file modification, shadow-copy deletion, entropy changes) and therefore act only once damage is underway on a given host. They have no native model of how the infection will *propagate*, and so cannot pre-emptively sever the lateral-movement paths along which it spreads. What is missing is a defensive capability that treats the network itself as the object of analysis and intercepts propagation before encryption, rather than reacting to encryption after the fact.

The deployment context sharpens this requirement further. Real incident-response practice and industry reporting consistently describe ransomware operators spending a "dwell time" of anywhere from hours to weeks moving laterally before triggering encryption, and increasingly favour *coordinated*, near-simultaneous encryption across many hosts once a sufficient foothold is established, precisely because a staggered, one-host-at-a-time detonation gives defenders an early, correctable signal[3,4]. A defence that only ever reacts to the first visible detonation is therefore implicitly assuming a particular, relatively forgiving attacker timing; a security case for any proactive defence should state, and ideally test, how it behaves when that assumption is relaxed. This motivates not only proposing an early-interception mechanism but explicitly stress-testing it against a more patient, coordinated adversary model, which is one of the contributions of this extended study.

We argue that ransomware propagation is naturally modelled as a dynamic process on a graph, and that this view enables *early interception*. An enterprise network is a graph whose nodes are devices each with a measurable attack surface (unpatched vulnerabilities, exposed services, privilege level) and whose edges are the lateral-movement opportunities between devices, whose likelihood can be estimated from historical authentication and access patterns. Ransomware spread is then a contagion on this weighted, directed graph. Crucially, during an incident the defender does not observe the full infection state; it observes only the hosts that have begun encrypting (the visible detonations) and the static asset graph. The defensive problem is to infer, from this partial and noisy signal together with the network structure, which hosts are *silently compromised* or imminently at risk, and to isolate the highest-impact of them before they spread or detonate.

We address this problem with a graph attention network (GAT). The network topology and authentication-derived edge weights form a dynamic knowledge graph; node features combine static attack-surface attributes with dynamic indicators derived from the currently visible encryption pattern. Trained on simulated historical campaigns, the GAT predicts, for every host, the probability that it is part of the hidden propagation front. A containment-aware interception policy then isolates the top-ranked hosts weighting predicted risk by each host's capacity to spread thereby cutting the propagation tree early. The entire pipeline runs on-premise from the organisation's own network and authentication telemetry, with no dependence on external threat-intelligence feeds.

To evaluate the approach without deploying or authoring any malicious software, we build an abstract propagation simulator: ransomware spread is represented as a probabilistic contagion on the weighted enterprise graph an epidemic/percolation- style dynamic structured around MITRE ATT&CK lateral-movement tactics. The simulator contains no exploit code, no payload, and no operational attack technique; it is a model of *how a contagion moves* on a network, used solely to study defence. Within this environment we compare the proposed GAT interception against endpoint-only detection, several heuristic isolation strategies, a graph convolutional network

(GCN) ablation, an ensemble of the two, and an omniscient oracle, under both the standard (per-host dwell) timing model and the more adversarial patient-attacker timing model introduced in this study.

Contributions:

- We formulate ransomware early interception as the prediction of a hidden contagion front on a dynamic enterprise knowledge graph, observed only through visible encryption events and static attack-surface attributes, and give a formal problem statement and notation ("Problem formulation and preliminaries").
- We design a graph attention network and a containment-aware isolation policy that proactively sever lateral-movement paths before encryption, running entirely on-premise, and establish simple structural properties of the isolation policy ("The isolation policy and its structural properties").
- We build an abstract, MITRE ATT&CK-structured propagation simulator and conduct a controlled evaluation, finding that graph-based interception reduces mean encrypted file value by 85% (median 98%) relative to endpoint-only detection, and substantially outperforms heuristic isolation, while remaining effective even when encryption begins on the first affected host.
- We show that most of this advantage is already obtained when the GAT is trained on a single enterprise network (76.2% reduction, rising to 89.6% with four) ("Generalisation across the number of training networks"), indicating the learned propagation cues generalise across topology rather than memorising a specific network.
- We introduce and evaluate, for the first time in this line of work, an abstract *patient attacker* that delays visible encryption to deny the defender its primary dynamic signal, and show that all detonation-reactive defenses including ours lose their advantage as the silent dwell grows, identifying a genuine limitation and motivating complementary, non-detonation- triggered defences ("Robustness to a patient (synchronised-detonation) attacker").
- We report honest comparisons throughout, including the finding that a GCN ablation matches the GAT on raw node-level prediction and slightly outperforms it on interception, while the graph-based policies as a class substantially outperform non-graph heuristics; that an ensemble of the two gives the best mean containment and the smallest outcome spread ("An ensemble of GAT and GCN"); and we characterise where the approach is strongest and where it degrades (server breaches, larger networks, patient attackers).

Novelty and scope of the contribution: We state plainly what is and is not new here, since this framing determines how the results should be read. We do *not* claim a new graph-neural-network operator: the GAT and GCN we use are standard architectures, applied without modification to their message-passing or attention mechanisms. The novelty is instead at three other levels. (i) *Formulation*: we cast ransomware early interception as prediction of a *hidden contagion front* on a dynamic enterprise knowledge graph, observed only through visible detonations and static attack-surface features, and reduced to a downstream containment objective (encrypted file value) rather than a node-level detection metric, a target that, to our knowledge, has not been posed in this form for ransomware. (ii) *Policy with structural guarantees*: the containment-aware isolation policy that converts per-node risk into high-impact targeting is a distinct algorithmic contribution, for which we prove monotonicity in the isolation budget (Proposition 1) and degeneracy under withheld signal (Proposition 2); these are properties of the *defensive procedure*, not of the underlying GNN. (iii) *Adversarial-timing characterisation*: we introduce a patient-attacker model and show, formally and empirically, the regime in which *any* detonation-triggered defence, including ours, must fail, which reframes the practical claim from "a better detector" to "a well-characterised layer in defence-in-depth, with its failure mode made explicit". The consistent finding that a non-graph heuristic nearly matches the GNNs on node-level AUC while the graph *policies* substantially outperform non-graph heuristics on interception ("Predicting the hidden infection front" to "Early interception sharply reduces encryption") is itself evidence that the contribution lives in the formulation and policy, not in architectural novelty. We therefore regard the modest architectural footprint as a feature of an honest account rather than a gap to be concealed.

## Related work

### Ransomware detection and response

The dominant paradigm for ransomware defence is behavioural detection at the endpoint: monitoring file-system activity for the signatures of encryption (mass modification, entropy increase, shadow-copy deletion) and triggering containment once those signatures appear[3,4]. Surveys of the field consistently report that detection accuracy is high once encryption is underway, but that this is, definitionally, *after* the payload has begun acting, and that propagation prior to detonation is comparatively under-addressed. Network-level approaches to lateral- movement detection, often based on authentication-graph anomaly detection, target the propagation phase directly[5], but typically score individual anomalous edges or sessions rather than modelling the contagion dynamics of an active campaign or producing a containment policy. Our work sits at the intersection: it uses a network/graph view, like lateral-movement detection, but is organised around predicting and intercepting the hidden *infection front* of an active campaign, evaluated by its effect on the operational outcome (encrypted files), not only on a detection metric.

### Epidemic and contagion modelling for cyber propagation

Modelling malware and worm propagation as an epidemic process on a network has a long history, from early directed-graph models of computer-virus spread[6] to the broader literature on epidemic processes on complex networks[7,8]. This literature establishes the contagion formalism we adopt compromise as a stochastic process governed by a network's structure and edge transmission probabilities and gives the qualitative expectation that network topology strongly shapes outbreak size and containability. Our contribution relative to this literature is to attach a learned, supervised *defensive* policy to the contagion (rather than only characterising outbreak statistics under fixed policies) and to evaluate that policy's robustness to adversarial timing, which the classical epidemic literature, focused on naturally occurring contagions, does not consider.

### Graph neural networks for security

Graph neural networks have been applied broadly across security tasks, including malware classification, intrusion and anomaly detection on provenance and authentication graphs, and fraud detection[9,10]. These applications generally use a GNN as a *classifier* over a largely static graph. Our use is different in kind: the graph is dynamic (the attacker is actively changing the infection state during the prediction window), the prediction target is the hidden state of an ongoing adversarial process rather than a static label, and the GNN's output feeds directly into a containment policy whose effect on a downstream physical outcome (encrypted files) is what we evaluate, rather than the classifier's discrimination metrics alone. We note that our training-coverage result ("Generalisation across the number of training networks") is consistent with the broader finding that GNNs using inductive, neighbourhood-aggregation formulations generalise to unseen graphs rather than requiring transductive access to the test graph during training[11]; our networks differ in topology instance but share a generative family ("Enterprise network model"), so this is a weaker generalisation claim than fully out-of-distribution graph transfer, which we discuss as a limitation.

### Proactive isolation and moving-target defence

A complementary line of work studies proactive network segmentation, moving-target defence, and deception (honeypots, honeytokens) as ways to disrupt lateral movement independently of detecting any specific intrusion. These approaches are valuable precisely where our patient-attacker results ("Robustness to a patient (synchronised-detonation) attacker") show detonation-reactive defences including the proposed GAT policy lose their

advantage: because they do not depend on observing a detonation at all, they remain effective regardless of how long an attacker is willing to wait silently. We discuss this complementarity explicitly in "Discussion" rather than treating proactive isolation and graph-based interception as competing alternatives.

### Positioning summary

Table 1 summarises, qualitatively, how the proposed approach relates to these strands on the properties most relevant to operational deployment.

## Problem formulation and preliminaries

### Problem statement

The enterprise is modelled as a weighted directed graph $G = (V, E)$ with $N = |V|$ hosts. Each host $i \in V$ carries static attack-surface attributes $\mathbf{a}_i$ (vulnerability score, privilege level, file value/criticality, server flag) and structural attributes derivable from $G$ (out-degree, weighted in-degree). Each directed edge $(i, j) \in E$ carries a weight $w_{ij} \in (0, 1)$ representing lateral-movement likelihood, abstracted from authentication and service-exposure patterns. At time step $t$, every host is in one of four states, $s_i(t) \in \{\textsc{clean}, \textsc{compromised}, \textsc{detonated}, \textsc{isolated}\}$; the defender observes only the set of currently detonated hosts $\mathcal{D}(t) = \{i : s_i(t) = \textsc{detonated}\}$ and the static graph, not the true compromised set. The defensive task is, at every step, to choose a small set of non-detonated hosts to isolate so as to minimise the total file value eventually encrypted, using only $\mathcal{D}(t)$, $G$, and $\{\mathbf{a}_i\}$. Table 2 summarises the notation used throughout.

### Contagion preliminaries

Spread is a discrete-time stochastic contagion: a host that is compromised or detonated and not isolated infects each clean neighbour $j$ independently with probability $p_{ij} = \text{clip}(\beta\, w_{ij}\, \sigma_j, 0, 0.98)$, where $\sigma_j$ is $j$'s susceptibility and $\beta$ scales overall aggressiveness; this is the standard formalism for contagion on weighted graphs used in the epidemic-modelling literature[7,8], specialised here to a directed, host-level network with heterogeneous edge weights. Two timing models govern when a compromised host's encryption becomes visible to the defender: the *standard* model, in which each host independently detonates after a fixed dwell $\tau$ since its own compromise ("Standard (per-host dwell) propagation model"), and the *patient-attacker* model introduced in this study, in which detonation across all currently compromised hosts is withheld and synchronised to a single trigger step $T_{\text{trig}}$

**Table 1** Qualitative positioning relative to related defensive paradigms. "Dynamic contagion model" denotes whether the approach models the active spreading process (not just a static graph); "containment policy evaluated" denotes whether the work measures effect on a physical outcome (e.g. encrypted files) rather than only a detection metric; "adversarial-timing robustness evaluated" denotes whether the work tests behaviour against an attacker that adapts its timing to evade the defence's signal.

| Approach | Dynamic contagion model | Containment policy evaluated | Adversarial-timing robustness evaluated |
|---|---|---|---|
| Endpoint behavioural detection[3,4] | No | Implicit (reactive) | Not evaluated |
| Lateral-movement anomaly detection[5] | No | No (scores edges) | Not evaluated |
| Epidemic models of malware spread[6,7] | Yes | Not policy-linked | Not evaluated |
| GNN classifiers for security[9,10] | No (static graph) | No | Not evaluated |
| Proactive segmentation / deception | n/a | Yes (by design) | Robust by construction |
| **This work** | **Yes** | **Yes** | **Evaluated** ("Robustness to a patient (synchronised-detonation) attacker") |

Significant values are in bold.

**Table 2** Summary of notation.

| Symbol | Meaning |
|---|---|
| $G = (V, E)$, $N = \|V\|$ | Enterprise network graph; number of hosts |
| $w_{ij} \in (0, 1)$ | Lateral-movement likelihood on edge $(i, j)$ |
| $\mathbf{a}_i$ | Static attributes of host $i$ (vulnerability, privilege, files, server flag) |
| $s_i(t)$ | State of host $i$ at step $t$: clean / compromised / detonated / isolated |
| $\mathcal{D}(t)$ | Set of *visibly* detonated hosts at step $t$ (the defender's only dynamic signal) |
| $\tau$ | Per-host dwell time before detonation (standard timing model) |
| $T_{\text{trig}}$ | Synchronised-detonation trigger step (patient-attacker timing model) |
| $\beta$ | Spread-aggressiveness scale |
| $\sigma_j$ | Susceptibility of target host $j$ |
| $\hat{y}_i \in [0, 1]$ | GAT-predicted probability that host $i$ is a hidden (compromised, non-detonated) foothold |
| $k$ | Per-step isolation budget |
| frac_encrypted | Fraction of total file value encrypted at campaign end (primary outcome metric) |

("Patient-attacker (synchronised-detonation) propagation model"). Both models describe only the abstract *timing* of an already-abstract contagion; neither specifies, nor requires, any concrete exploitation technique.

### Evaluation concepts

The primary outcome metric is frac_encrypted, the fraction of total network file value encrypted by campaign end; we report its mean, median and standard deviation over repeated campaigns, and its *reduction relative to endpoint-only detection*, $100 \times (\bar{e}_{\text{endpoint}} - \bar{e}_{\text{method}})/\bar{e}_{\text{endpoint}}$. For the node-level prediction task (does the GAT correctly identify hidden footholds) we use the area under the ROC curve (AUC), average precision (AP), and precision among the top-$k$% highest-scored hosts, all standard for imbalanced binary prediction. Because campaigns under a fixed breach and random seed are paired across defences (common random numbers), reported differences between defences reflect the defence alone rather than sampling noise in the contagion itself.

## Methods

Before describing the components, we state the nature of the simulator explicitly, as requested in review. Everything below is an *abstract defensive evaluation environment*: an epidemic/percolation-style probabilistic contagion on a weighted graph, instrumented to measure how well a defender contains spread. It is *not* an operational ransomware implementation. There is no encryption routine, no exploit, no payload, no command-and-control, and no lateral-movement tooling of any kind; "detonation" is simply a state label on a graph node marking when simulated file value is counted as lost, and "spread" is a random draw over edges. MITRE ATT&CK is referenced only at the tactic level to make scenarios plausible, not to reproduce any technique. The environment exists solely to evaluate the proposed defence and could not be used to conduct an attack.

### Enterprise network model

A network of $N$ hosts is generated with $\lceil N/60 \rceil$ subnets. Each host is assigned to a subnet, and approximately 8% of hosts are designated servers. Host attributes are drawn as follows: a vulnerability score $v_i \in (0, 1)$ (Beta-distributed, servers slightly hardened), a privilege level $\pi_i \in (0, 1)$ (servers elevated), and a file/criticality value drawn log-normally and multiplied by a large factor for servers (so the server tier concentrates data). Directed lateral-movement edges are created intra-subnet (peer links), from hosts to servers (shared services, authentication), and from servers outward to many hosts (administrative reach); each edge carries a weight $w_{ij} \in (0, 1)$ representing

lateral-movement likelihood, abstracted from authentication and service-exposure patterns. Duplicate directed pairs are max-aggregated. The susceptibility of a target is $\sigma_j = \mathrm{clip}(0.55\,\upsilon_j + 0.45\,\pi_j,\ 0.02,\ 0.99)$.

### Standard (per-host dwell) propagation model

Spread is a discrete-time probabilistic contagion. A single host is initially compromised. At each step: (i) the defence policy may isolate hosts; (ii) each compromised host that has been infected for at least the dwell time $\tau$ detonates, adding its file value to the encrypted total (once); (iii) every attacker-controlled host (compromised or detonated) that is not isolated infects each clean neighbour $j$ with probability $p_{ij} = \mathrm{clip}(\beta\, w_{ij}\, \sigma_j,\ 0,\ 0.98)$. The process runs until no attacker-controlled hosts remain or a step cap is reached. The simulator implements *no* exploit, payload, or attack technique; it models contagion dynamics only, structured around MITRE ATT&CK lateral-movement tactics for scenario realism. Canonical settings are $N = 300$, $\tau = 2$, $\beta = 0.6$, and a step cap of 40.

### Patient-attacker (synchronised-detonation) propagation model

To stress-test detonation-reactive defences against a more deliberate adversary, we introduce a second timing model. Rather than each host detonating independently after its own dwell $\tau$, *all* hosts compromised by a designated trigger step $T_{\mathrm{trig}}$ detonate *simultaneously* at $T_{\mathrm{trig}}$; any host compromised after the trigger detonates immediately (representing the attacker's encryption tooling now being actively deployed across the foothold). Spread dynamics (step (iii) above) are unchanged. This models a real and widely reported ransomware tactic extended silent lateral movement followed by coordinated, near-simultaneous encryption[3,4] using only a change to the abstract timing of detonation visibility; it introduces no new attacker capability, exploit, or technique beyond the standard model. Crucially, before $T_{\mathrm{trig}}$ the defender's only dynamic signal, $\mathcal{D}(t)$, is *empty*, so any defence including the proposed GAT that relies on visible detonation pressure has no dynamic information to act on until the trigger step; we use this property to characterise a genuine limitation in "Robustness to a patient (synchronised-detonation) attacker". We note that this timing model is itself a modelling contribution relative to the classical epidemic and worm-propagation literature ("Epidemic and contagion modelling for cyber propagation"), which treats contagions as naturally occurring processes with exogenous, non-strategic dynamics. Here detonation *timing* is an adversarial decision variable chosen to defeat the defender's observation model, coupling the contagion process to the defence in a way standard susceptible–infected dynamics do not capture. This adversarial-timing coupling, and its formal consequence in Proposition 2, is a distinct propagation-modelling element of this work rather than a reuse of a textbook epidemic model.

### Dynamic knowledge graph and node features

At any moment the defender observes the set of detonated (encrypting) hosts and the static graph. Each host is described by a 12-dimensional feature vector combining static attributes vulnerability, privilege, log-file-value, server flag, normalised out-degree, authentication centrality (weighted in-degree), and normalised out-strength (spread capacity) with dynamic indicators derived from the visible detonation set: the incoming lateral-movement pressure from detonated neighbours, the fraction of in-neighbours detonated, a two-hop pressure term, the (capped) hop distance to the nearest detonated host, and a flag for the host's own visible state. These features form the input to the graph models. Under the patient-attacker model, all five dynamic features are identically zero for every host until $T_{\mathrm{trig}}$, so the GAT's pre-trigger ranking is driven entirely by the seven static features.

### Graph attention network

The predictor is a two-layer graph attention network[12]. Each layer linearly transforms node features, $\mathbf{h}'_i = \mathbf{W}\mathbf{h}_i$, and computes attention coefficients over incoming edges using the standard additive form $e_{ij} = \mathrm{LeakyReLU}(\mathbf{a}_\ell^\top \mathbf{h}'_i + \mathbf{a}_r^\top \mathbf{h}'_j)$

, normalised across each node's neighbourhood by a softmax, $\alpha_{ij} = \mathrm{softmax}_j(e_{ij})$, followed by aggregation $\mathbf{h}_i'' = \mathrm{ELU}(\sum_j \alpha_{ij}\mathbf{h}_j')$ with self-loops. A final linear layer produces a per-host logit, passed through a sigmoid to yield an infection probability $\hat{y}_i$. The GCN ablation replaces attention with symmetric degree normalisation[13], the standard graph convolutional formulation. Both are implemented from first principles in a small reverse-mode automatic-differentiation engine; the gradients were verified against finite differences to a maximum error of $2\times10^{-10}$. Models have hidden width 32 and are trained with Adam (learning rate $5\times10^{-3}$, weight decay $10^{-5}$) to minimise binary cross-entropy, masked to non-detonated hosts, over snapshots of simulated campaigns.

## The isolation policy and its structural properties

Given predicted probabilities $\hat{y}_i$, the GAT (and GCN) policy isolates the top-$k$ non-detonated hosts ranked by $\hat{y}_i \cdot (\mathrm{outstr}_i + 0.5 + 3 \cdot \mathrm{is_server}_i)$, i.e. predicted risk weighted by spread capacity, with extra priority on servers. Algorithm 1 states the full containment-aware interception procedure explicitly. We emphasise that this policy, not the choice of GNN, is the component that converts per-node risk scores into the large interception gains of "Results": it is the mapping from a calibrated risk field to a budget-constrained, spread-weighted isolation set, and it is what distinguishes our approach from a bare node classifier (which the pressure heuristic shows is insufficient on its own, Table 4). The score multiplies predicted infection probability by a spread-capacity term so that the budget is spent on the hosts whose isolation removes the most future propagation, not merely the hosts most likely to be infected a distinction that a pure classification objective does not capture.

**Input:** network $G = (V, E)$ with edge weights $w$; static attributes $\mathbf{a}$; per-step budget $k$; trained risk model $f_\theta$ (GAT or GCN)
**State:** detonated set $\mathscr{D} \leftarrow \varnothing$; isolated set $\mathscr{I} \leftarrow \varnothing$
**for** each time step $t = 1, 2, \ldots$ until campaign ends **do**
  observe visible detonations $\mathscr{D}(t)$ on non-isolated hosts
  build dynamic features $\mathbf{d}_i(t)$ from $\mathscr{D}(t)$ and $G$ ▷ zero if $\mathscr{D}(t) = \varnothing$ (Prop. 2)
  $\hat{y}_i \leftarrow f_\theta(\mathbf{a}_i, \mathbf{d}_i(t), G)$ for all $i \notin \mathscr{D} \cup \mathscr{I}$ ▷ predicted hidden-foothold prob.
  $s_i \leftarrow \hat{y}_i \cdot (\mathrm{outstr}_i + 0.5 + 3 \cdot \mathrm{is_server}_i)$ ▷ risk × spread capacity
  $\mathscr{S} \leftarrow$ indices of the $k$ largest $s_i$ among non-detonated, non-isolated hosts
  $\mathscr{I} \leftarrow \mathscr{I} \cup \mathscr{S}$; remove $\mathscr{S}$ from $G$ ▷ proactive isolation before encryption
  advance contagion one step on the remaining graph (Sections 4.2–4.3)
**end for**
**return** encrypted-file fraction at campaign end

**Algorithm 1** Containment-aware early-interception policy (one campaign).

We note two simple but operationally important properties of this containment-aware ranking, both of which follow directly from its definition.

**Proposition 1** (Budget monotonicity) *For fixed predictions $\hat{y}$ and a fixed campaign realisation, the set of hosts isolated under budget $k$ is a subset of the hosts isolated under any budget $k' > k$ at the same step, so the resulting encrypted fraction is weakly decreasing in $k$.*

***Proof*** (Justification) The top-$k$ hosts by a fixed score are, by definition, a subset of the top-$k'$ hosts for $k' > k$; isolating a (weak) superset of hosts can only remove additional attacker-controlled or vulnerable hosts from the propagation graph, which cannot increase the eventual encrypted total under the (monotone) spread dynamics of "Standard (per-host dwell) propagation model" and"Patient-attacker (synchronised-detonation) propagation model". □

**Proposition 2** (Zero-signal degeneracy) *If $\mathscr{D}(t) = \emptyset$ for all $t < T$ for some $T$ (no detonation has yet occurred), the GAT's dynamic features are identically zero for every host at every $t < T$, so its ranking is determined entirely*

*by the static attributes* $\mathbf{a}_i$ *and graph structure, and is therefore identical, up to the model's learned weighting of those static features, across any two campaigns that share a network but differ only in which (still-silent) hosts are truly compromised.*

***Proof*** (Justification) Inspection of the feature construction in "Dynamic knowledge graph and node features": every dynamic feature is a function of $\mathcal{D}(t)$ (detonated-neighbour pressure, fraction of daetonated in-neighbours, two-hop pressure, hop-distance to detonation, own-detonation flag), and each is zero (or, for hop-distance, at its capped maximum) whenever $\mathcal{D}(t) = \emptyset$. □

***Remark 1*** Proposition 2 is the formal statement of the limitation explored empirically in "Robustness to a patient (synchronised-detonation) attacker": under a patient attacker who withholds detonation, the GAT cannot outperform a purely static-attribute ranking (such as the degree- or vulnerability-based heuristics) until the first detonation is observed, regardless of how well the model has been trained on the dynamic phase. This is a property of the *observation model*, not of the GAT architecture, and would apply identically to any classifier restricted to the same visible signal.

## A worked numerical example

To make the dynamic-feature mechanism concrete, consider a toy network of four hosts $\{A, B, C, D\}$ with edges $A \to B$ $(w = 0.8)$, $B \to C$ $(w = 0.6)$, $B \to D$ $(w = 0.5)$, all with susceptibility $\sigma = 0.7$, and suppose $A$ is the initial breach. Under the standard model with $\tau = 2$: at step 2, $A$ detonates (it has been compromised since step 0); $B$, infected at step 1 with probability $p_{AB} = \beta\, w_{AB}\, \sigma_B = 0.6 \times 0.8 \times 0.7 = 0.336$, is by step 2 visible as a one-hop neighbour of a detonated host, so its incoming-pressure feature is $\text{press}_B = w_{AB} = 0.8$, a strong signal that correctly flags $B$ as high risk *before* $B$ itself detonates (at step 3 at the earliest). Under the patient model with $T_{\text{trig}} = 6$: $A$, $B$, and possibly $C$, $D$ may all be silently compromised by step 6, yet $\mathcal{D}(t) = \emptyset$ for every $t < 6$, so $\text{press}_B = 0$ throughout the GAT receives no dynamic signal that $B$ is at elevated risk until the synchronised detonation at step 6, by which point $B$ (and possibly $C$, $D$) are already encrypting. This toy example isolates, at minimal scale, exactly the mechanism quantified at full network scale in Section Robustness to a patient (synchronised-detonation) attacker.

## Computational complexity

Let $N$ be the number of hosts and $|E|$ the number of edges. Computing the dynamic features ("Dynamic knowledge graph and node features") is $O(|E|)$ per step (one pass over edges for first-hop pressure, one further pass for two-hop pressure, and a capped breadth-first search for hop-distance, itself $O(|E|)$ with a constant depth cap). A forward pass of the two-layer GAT is $O(|E|\,H)$ for hidden width $H$, dominated by the attention computation over edges; the isolation ranking is an $O(N \log N)$ sort. The per-step cost of the proposed defence is therefore $O(|E|\,H)$, linear in the size of the network and independent of the campaign length, and in our implementation a full 40-step campaign on a 300-host network (2,659 directed edges on average) takes about 36 ms of single-core CPU time, including a GAT forward pass at every step, consistent with on-premise, real-time deployment.

## Reproducibility and hyperparameters

The GAT and GCN use hidden width $H = 32$ (main models; $H = 24$ for the training-coverage sweep, Section Generalisation across the number of training networks, to keep the sweep computationally tractable), 2 layers, Adam optimisation (learning rate $5 \times 10^{-3}$, weight decay $10^{-5}$), and are trained for 20 epochs (10 for the training-coverage sweep) on snapshots drawn from 12 unmitigated campaigns per training network at steps $\{2, 3, 4, 5, 6, 8, 10, 12\}$ after the first compromise. The GAT uses a single attention head whose scores depend on node embeddings only (edge

weights enter through the pressure features), and the GCN operates on the symmetrised, self-looped adjacency. Campaign $c$ on network $s$ uses random seed $1000s + c$, and all defences facing a campaign share its random draws. Training and held-out validation networks are always disjoint from the further-held-out networks used for interception evaluation ("Training and evaluation protocol"); no hyperparameter was tuned on the patient-attacker or training-coverage test configurations, so the corresponding results ("Generalisation across the number of training networks" to "Robustness to a patient (synchronised-detonation) attacker") reflect genuine generalisation. All seeds are listed alongside each experiment in the accompanying code so every reported number can be regenerated exactly. The complete code is deposited at https://doi.org/10.5281/zenodo.XXXXXXX (see "Code availability").

### Training and evaluation protocol

Training snapshots are generated by running unmitigated campaigns on a set of networks and recording, at several time steps after the first compromise, the visible detonation pattern (input) and the set of silently compromised hosts (label). Models are trained on six networks and validated on two held-out networks for AUC ("Generalisation across the number of training networks" varies this from one to six); all interception evaluation uses additional networks that appear in neither training nor validation. Interception is measured by the fraction of total file value encrypted, averaged over campaigns; defence strategies are compared on *paired* campaigns sharing the same initial breach and the same random seed (common random numbers) so that differences reflect the defence alone. The reported reduction is relative to endpoint-only detection.

### Defence strategies

*Endpoint-only* isolates each host when it detonates (reactive). *Random*, *degree-ranked*, and *vulnerability-ranked* isolate $k$ non-detonated hosts per step by the respective criterion. *Frontier* isolation targets clean or compromised neighbours of visibly detonated hosts, weighted by edge weight and target vulnerability. The *GAT* and *GCN* policies score every host by predicted infection probability and isolate the top $k$ non-detonated hosts ranked by predicted risk times spread capacity ("The isolation policy and its structural properties"). The *ensemble* policy ("An ensemble of GAT and GCN") averages the GAT and GCN probabilities before ranking. The *oracle* isolates truly compromised hosts (prioritised by connectivity), providing an upper bound. All proactive policies act only once encryption is visible (or, under the patient model, only once any dynamic signal exists) and isolate at most $k$ hosts per step; the canonical budget is $k = 8$. Precisely, degree-ranked isolation uses total (in plus out) degree; the frontier score of host $j$ is $v_j \sum_{i \in \mathcal{D}(t)} w_{ij}$ and only hosts with a positive score are eligible; and the oracle ranks truly compromised, non-detonated hosts by out-strength. Proactive policies spend their budget only on non-detonated hosts and do not additionally disconnect hosts already seen detonating, so a policy that spends its budget poorly can end up worse than endpoint-only isolation.

## Results

### Modelling ransomware propagation and interception

We model an enterprise network of $N$ devices as a weighted directed graph (Methods). Workstations are organised into subnets, and a server tier (file servers and domain controllers, ~8% of hosts) bridges them and concentrates data. Ransomware spread is simulated as a probabilistic contagion ("Standard (per-host dwell) propagation model"); the defender observes only detonated (encrypting) hosts and the static asset graph, and may isolate a limited number of hosts per step. Figure 1 summarises the pipeline: network and authentication logs form a

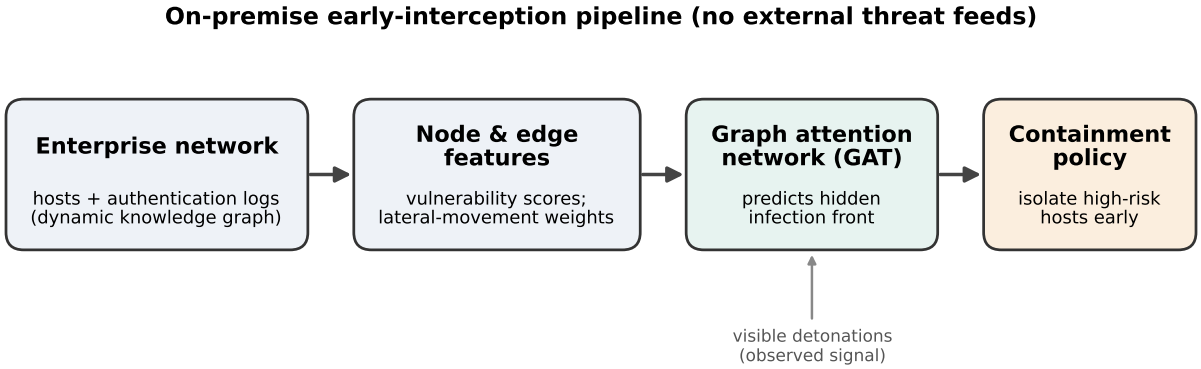



**Fig. 1** The proposed early-interception pipeline. The enterprise network and its authentication logs are represented as a dynamic knowledge graph with vulnerability node attributes and lateral-movement edge weights. A graph attention network, trained on historical campaigns, predicts the hidden infection front from the visible encryption pattern, and a containment-aware policy proactively isolates high-risk hosts before they encrypt. The pipeline is on-premise and uses no external threat feeds.

**Table 3** Hidden-infection prediction quality on held-out networks (base infection rate 0.14). The GAT and GCN are comparable and modestly ahead of the non-graph heuristic on AUC, but not on average precision or precision-at-*k*; the large interception gap reported in Table 4 is therefore driven by the containment-aware ranking, not by node-level discrimination alone.

| Method | AUC | AP | P@5% | P@10% | P@20% |
|---|---|---|---|---|---|
| GAT (ours) | 0.885 | 0.480 | 0.34 | 0.33 | 0.30 |
| GCN | 0.882 | 0.531 | 0.44 | 0.37 | 0.32 |
| Pressure heuristic (non-graph) | 0.870 | 0.531 | 0.44 | 0.39 | 0.35 |

dynamic knowledge graph; a graph attention network predicts hidden infection risk; and a proactive policy isolates high-risk hosts before encryption.

## Predicting the hidden infection front

The core learning task is to recover the silently compromised hosts from the visible encryption pattern and the graph. We train the GAT on simulated campaigns over a set of networks and evaluate it on fully held-out networks ("Methods"). Table 3 and Fig. 2 report the result. The GAT attains an area under the curve (AUC) of 0.885, and a GCN ablation a comparable 0.882; a non-graph heuristic that scores hosts purely by the lateral-movement pressure arriving from visibly detonated neighbours reaches a slightly lower AUC of 0.870. Precision at the top of the ranking does not follow the AUC ordering: against a base infection rate of 0.14, the GAT flags truly compromised hosts in 0.34 of its top-5% of alerts, whereas the GCN and the heuristic both reach 0.44; on average precision the heuristic equals the GCN (0.531) and exceeds the GAT (0.480). Two messages follow. First, the dynamic encryption pattern carries strong signal about the hidden front, so even a simple heuristic predicts moderately well. Second, and as we show next, modest differences in node-level prediction translate into large differences in *interception*, because what matters operationally is not classifying every host but isolating the few highest-impact ones early.

## Early interception sharply reduces encryption

We next measure the operational outcome the fraction of the organisation's files that are encrypted under each defence, using paired campaigns with common random seeds on held-out networks, aggregated over four held-out networks and 16 campaigns each ("Methods"). Figure 3 and Table 4 report the results, including the mean, median and standard deviation of the encrypted fraction. Without any defence, the contagion saturates the network

https://doi.org/10.1038/s41598-026-75165-0

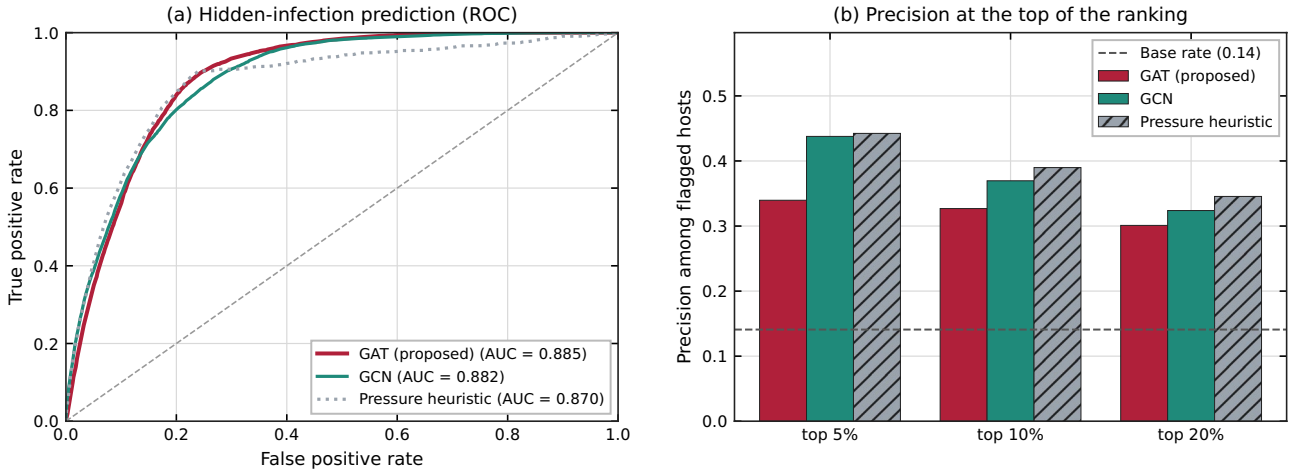



**Fig. 2** Predicting the hidden infection front on held-out networks. (**a**) ROC curves for the GAT, a GCN ablation, and a non-graph lateral-movement-pressure heuristic; the graph models are comparable and modestly ahead of the heuristic. (**b**) Precision among the top-$k$ flagged hosts against a base infection rate of 0.14 (dashed line); curves and bars are computed from the pooled validation snapshots.

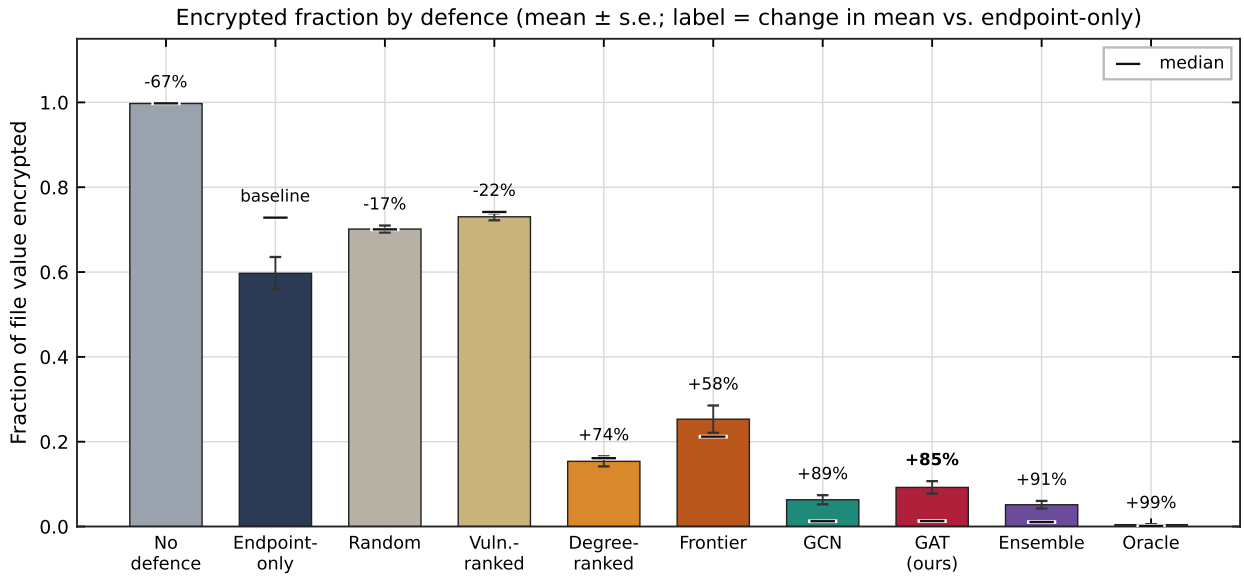



**Fig. 3** Fraction of files encrypted under each defence strategy on held-out networks, with the reduction relative to endpoint-only detection annotated. Random and vulnerability-only isolation are counter-productive; structure-aware heuristics help; and the graph-based policies (GCN, GAT) approach the omniscient oracle, reducing mean encryption by 85–91%. Bars show the mean with its standard error; black ticks mark the median.

and essentially all files are encrypted. Endpoint-only detection, which isolates each host as it begins encrypting, reduces the encrypted fraction only to a mean of 0.597: it removes detonating hosts but cannot stop the silent footholds they have already seeded, which continue to spread and encrypt. Naive proactive heuristics fare poorly or worse random and vulnerability-ranked isolation actually *increase* damage relative to endpoint-only by spending the isolation budget on the wrong hosts while structure-aware heuristics help substantially (degree-based and frontier isolation cut mean encryption by 74% and 58%). The graph-based interception is markedly more effective: the proposed GAT policy reduces mean encrypted file value by 85% relative to endpoint-only, and the GCN ablation by 89%, approaching the 99.3% reduction of an omniscient oracle that isolates truly infected hosts.

**Table 4** Encrypted-file fraction (mean, median, standard deviation over 4 held-out networks × 16 campaigns = 64 paired campaigns per strategy) and reduction in the mean relative to endpoint-only detection (canonical settings: $N = 300$, dwell = 2 , isolation budget $k = 8$). Lower encrypted fraction is better. For the graph-based policies the median is well below the mean, indicating a right-skewed outcome distribution ("Early interception sharply reduces encryption"); random and vulnerability-only isolation can be counter-productive; graph-based policies approach the omniscient oracle. The ensemble is evaluated on the same 64 paired campaigns as every other row.

| Strategy | Mean | Median | Std. dev. | Reduction vs. endpoint |
|---|---|---|---|---|
| No defence | 0.997 | 0.998 | 0.002 | −67.1% |
| Endpoint-only (reactive) | 0.597 | 0.728 | 0.308 | (baseline) |
| Random isolation | 0.701 | 0.701 | 0.066 | −17.5% |
| Vulnerability-ranked | 0.730 | 0.742 | 0.066 | −22.3% |
| Degree-ranked | 0.154 | 0.161 | 0.095 | +74.3% |
| Frontier (neighbour) isolation | 0.253 | 0.212 | 0.258 | +57.6% |
| GCN interception (ablation) | 0.063 | 0.012 | 0.086 | +89.4% |
| **GAT interception (proposed)** | 0.092 | 0.013 | 0.118 | +84.6% |
| Ensemble (GAT+GCN) | 0.051 | 0.011 | 0.072 | +91.4% |
| Oracle (omniscient) | 0.004 | 0.001 | 0.010 | +99.3% |

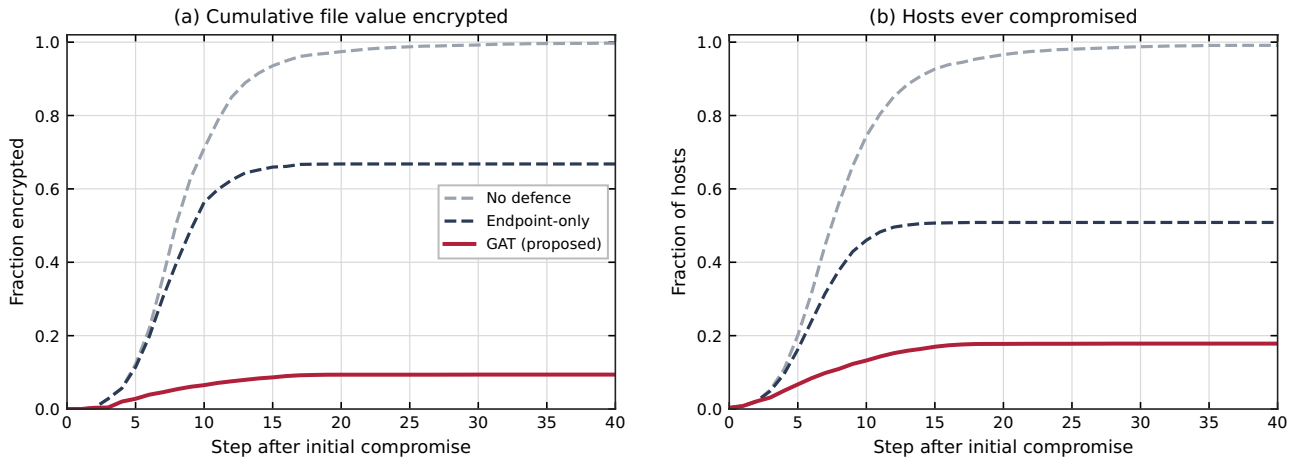



**Fig. 4** Containment over time (mean over 16 campaigns on a held-out network). (**a**) Cumulative fraction of file value encrypted and (**b**) fraction of hosts ever compromised, for no defence, endpoint-only detection, and the proposed GAT interception. Early proactive isolation flattens both curves within a few steps of the first visible encryption.

The GCN's mean is lower than the GAT's; we test this difference, and the others, in "Statistical robustness of the comparison". Averaging the two models' predictions (the ensemble of "An ensemble of GAT and GCN") gives the lowest mean of all non-oracle defences, 0.051 (91% reduction).

A notable feature of Table 4, which we report transparently rather than collapsing into a single summary statistic, is that the outcome distribution under the graph-based policies is strongly right-skewed: the *median* encrypted fraction under GAT is just 0.013 (essentially full containment), well below its *mean* of 0.092, with the gap driven by a minority of harder campaigns, consistent with the breach-location analysis of "Breach location and generalisation across network size", where server breaches are disproportionately difficult. The same pattern holds for the GCN and the ensemble but not for the heuristics, whose mean and median are close together (frontier 0.253 versus 0.212; degree-ranked 0.154 versus 0.161). We therefore report mean, median, and standard deviation throughout this section rather than the mean alone.

Figure 4 shows why interception works: it acts *early*. Tracking the cumulative encrypted fraction and the compromised-host fraction over time, the no-defence and endpoint-only curves climb steeply as the contagion propagates, whereas the GAT policy flattens both within a few steps of the first visible encryption, containing the

outbreak largely before it can reach the data-rich server tier. Endpoint-only detection also levels off, but only after 0.668 of the file value is encrypted (versus 0.094 under the GAT policy), because it is always one step behind the encryption it reacts to.

### Effect of the response budget

The defender's capacity the number of hosts $k$ that can be isolated per step governs the achievable containment. Figure 5 sweeps $k$ from 2 to 12. With a very small budget ($k = 2$) no proactive method contains the outbreak: the graph policies leave about half the file value encrypted (GAT 0.508, GCN 0.515), and the frontier heuristic (0.630) is worse than endpoint-only isolation (0.597). As the budget grows, the graph policies improve far faster than the frontier heuristic: by $k = 6$ the GAT holds mean encryption at 0.139 and by $k = 8$ at 0.092, whereas the heuristic needs $k = 12$ to reach 0.170. The GCN is at or slightly below the GAT for every $k \geq 4$, and both remain well below the heuristic, indicating that the graph models use a modest isolation budget far more efficiently by targeting high-impact hosts.

### Robustness to spread rate and detection delay

Real campaigns vary in how aggressively they move and how long they dwell before encrypting (under the standard, per-host timing model; the more adversarial synchronised-timing case is addressed separately in "Robustness to a patient (synchronised-detonation) attacker"). Figure 6a varies the lateral-movement aggressiveness $\beta$ from 0.4 to 0.8. As spread intensifies, endpoint-only damage rises steeply (0.372 to 0.736), and the frontier heuristic degrades (0.088 to 0.363), but the GAT policy keeps the encrypted fraction low across the range (0.022 to 0.170), still achieving a 77% reduction at the most aggressive setting tested; the GCN stays lower still (0.114 at $\beta = 0.8$). Figure 6b varies the dwell $\tau$ from 1 to 4 steps. Longer dwell makes interception harder for every method because more hosts are already compromised when the defender first sees encryption; nonetheless the GAT policy still removes 66% of encryption at $\tau = 4$ (0.297 vs. endpoint's 0.872) and 96% at $\tau = 1$ (0.008 vs. 0.215). At longer dwell the GCN holds up better than the GAT (0.191 at $\tau = 4$). Critically, when encryption begins almost immediately ($\tau = 1$, i.e. close to "encryption on the first affected host"), the GAT is at its most effective, because it intercepts the spread the moment the first signal appears the opposite regime from the patient-attacker stress test of "Robustness to a patient (synchronised-detonation) attacker", where the defender is denied that early signal altogether.

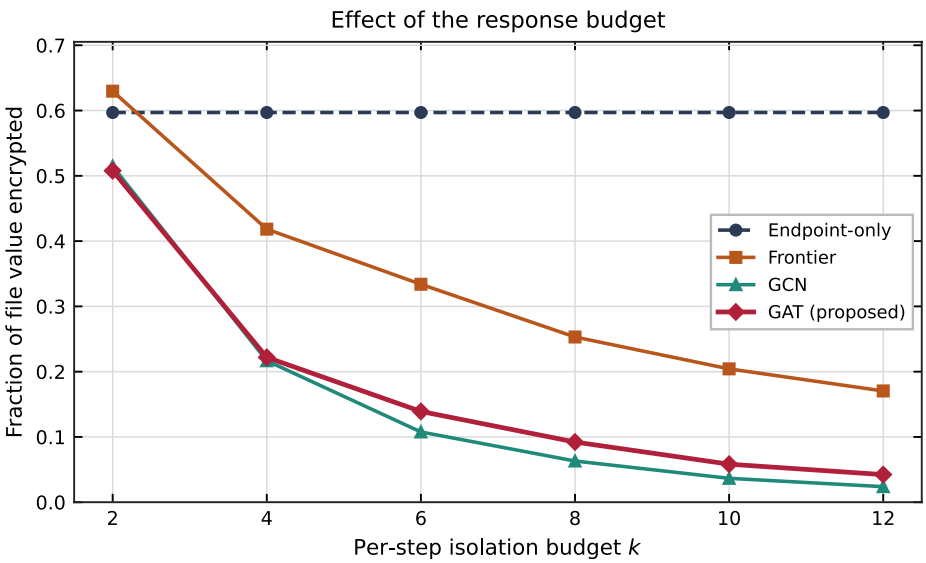



**Fig. 5** Effect of the per-step isolation budget $k$ on the encrypted fraction. Graph-based policies (GAT, GCN) convert budget into containment far more efficiently than the frontier heuristic; endpoint-only is shown for reference (dashed).

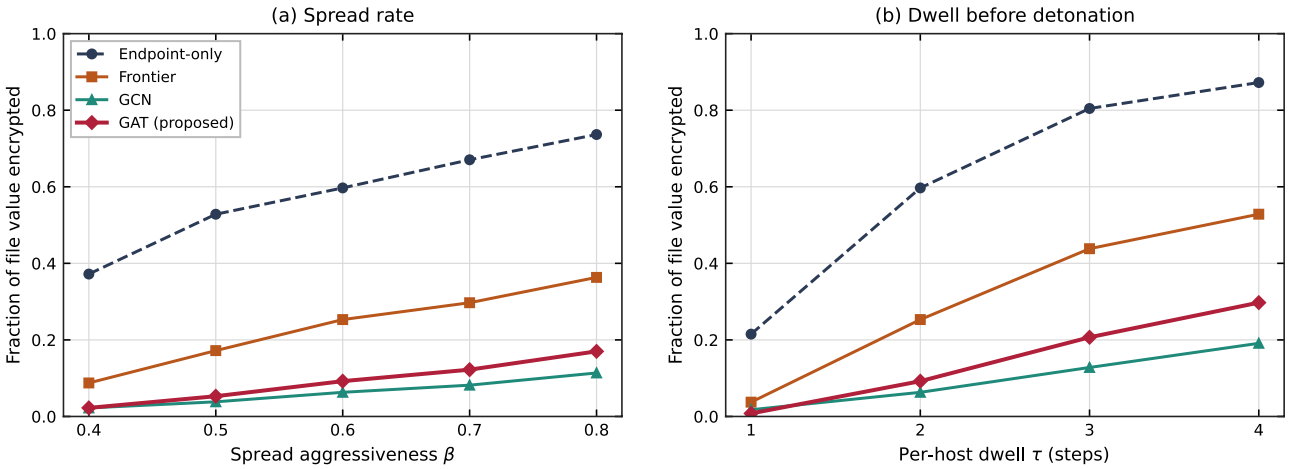



**Fig. 6** Robustness under the standard timing model. (**a**) Encrypted fraction versus lateral-movement aggressiveness; the GAT remains effective as spread intensifies. (**b**) Effect of per-host dwell before encryption; longer dwell (more silent pre-spread) is harder for all methods, but the graph policies retain a large advantage.

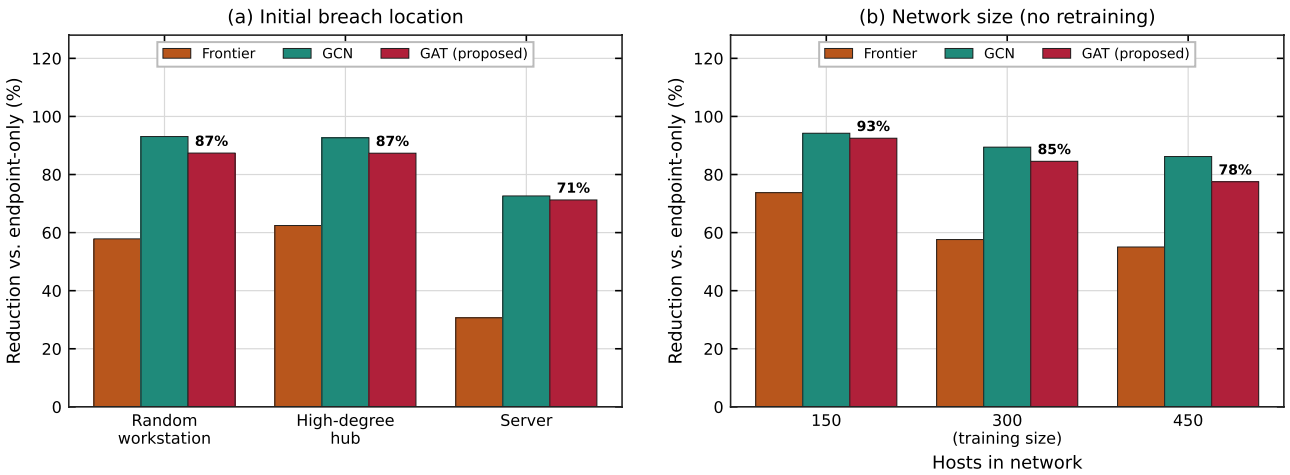



**Fig. 7** (**a**) Reduction in mean encrypted file value by initial breach location; server breaches are the hardest case. (**b**) A model trained only on 300-host networks is applied to networks of 150–450 hosts without retraining; its advantage declines with size at a fixed budget.

## Breach location and generalisation across network size

Figure 7a examines where the breach begins. When the initial foothold is a random workstation, the GAT reduces mean encryption by 87%. A breach that begins at a high-degree workstation hub is contained just as well (87%), because the hub's many out-edges quickly produce the visible signal the policy acts on. A breach that begins at a server is the hard case: servers hold most of the file value and reach many hosts at once, so the GAT's reduction falls to 71% (GCN 73%, frontier 31%). Server breaches are therefore the natural target for independent hardening, and the likely source of the right-skew noted in "Early interception sharply reduces encryption". Figure 7b tests generalisation across network *size*: a single model trained only on 300-host networks is applied, without retraining, to networks of 150, 300, and 450 hosts; it delivers reductions of 93%, 85%, and 78% respectively. The learned propagation cues therefore transfer across scale, but effectiveness declines as the network grows at a fixed budget of $k = 8$ hosts per step, so larger networks call for a proportionally larger budget or retraining at the

target size (the GCN declines less, from 94% to 86%). "Generalisation across the number of training networks" below complements this with a generalisation test across the *number of training networks* rather than their size.

## Interpretability

Because the GAT operates on the asset graph, its predictions are inspectable. Figure 8 overlays the GAT's predicted infection risk on a network snapshot a few steps into an incident, with the visibly encrypting hosts and the truly (but silently) compromised hosts marked. On this snapshot (step 5 of an unmitigated campaign on a held-out network, 9 detonated and 24 hidden footholds) the model assigns the hidden footholds a mean predicted risk of 0.22, about twice the 0.10 assigned to clean hosts, with the highest values around the visible encryption front and the server tier. This provides a security analyst with an actionable, ranked map of where the infection most likely already is rather than an opaque score. This supports human-in-the-loop response, in which the proposed isolations are reviewed before automated enforcement.

## Generalisation across the number of training networks

A practical concern for any learned defence is how many distinct enterprise networks it must see in training before it generalises to a new one. We train the GAT on 1, 2, 4, and 6 networks (with a fixed, disjoint pair of networks always used for AUC validation and three further, always-unseen networks used for interception evaluation; Methods) and measure both held-out AUC and mean interception reduction relative to endpoint-only. Table 5 and Fig. 9 report the result. Interception performance is already substantial with a single training network

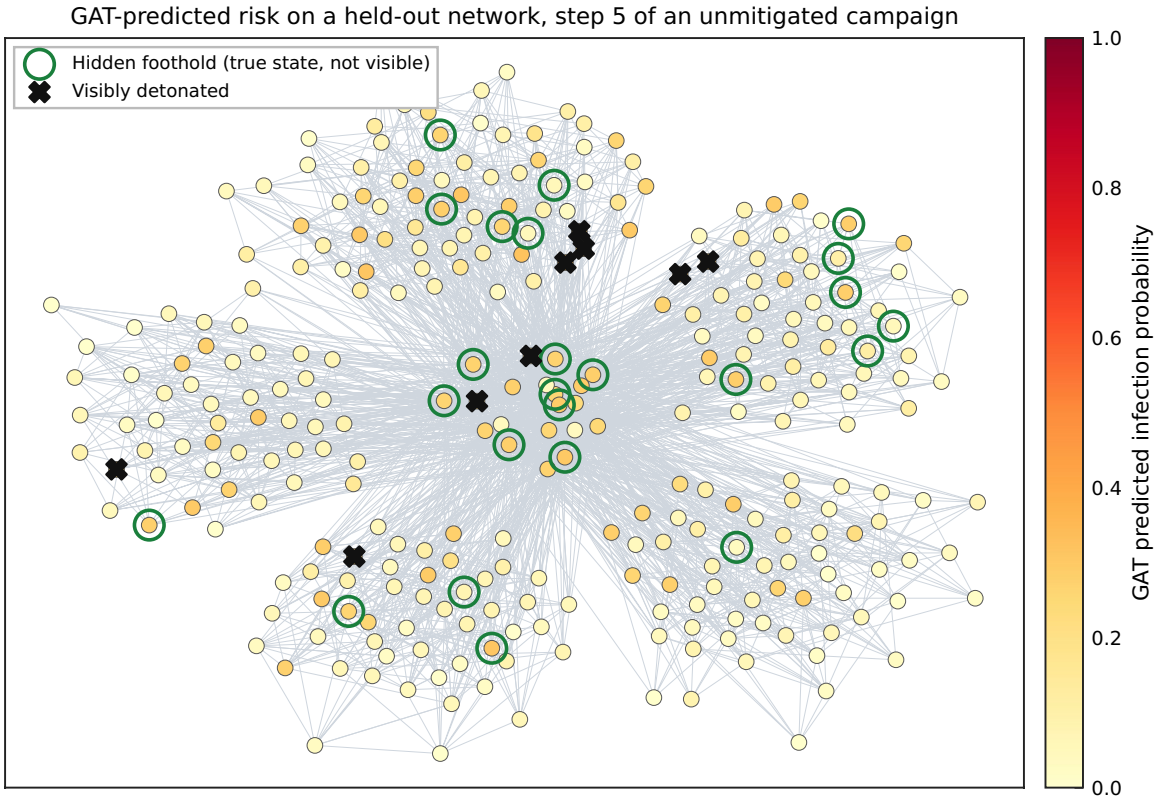



**Fig. 8** Interpretability. GAT-predicted infection risk (node colour) on a held-out network at step 5 of an unmitigated campaign; black crosses are visibly encrypting hosts and green rings are truly (silently) compromised hosts. Hidden footholds receive on average about twice the predicted risk of clean hosts (0.22 versus 0.10).

**Table 5** Generalisation across the number of training networks. Interception reduction is the mean over three always-held-out test networks, each evaluated with a fresh, distinct breach and campaign sample (10 campaigns each); AUC is measured on a fixed, disjoint pair of held-out validation networks. Interception performance is substantial even with a single training network and plateaus by four; AUC is noisier and non-monotonic, illustrating that it is an imperfect proxy for operational outcome.

| # Training networks | 1 | 2 | 4 | 6 |
|---|---|---|---|---|
| Validation AUC | 0.848 | 0.844 | 0.865 | 0.865 |
| Mean interception reduction vs. endpoint | 76.2% | 85.9% | 89.6% | 87.8% |
| Per-test-network reduction (3 networks) | 70.6/83.3/74.6% | 79.9/90.6/87.3% | 83.9/92.9/91.9% | 80.2/91.1/92.1% |

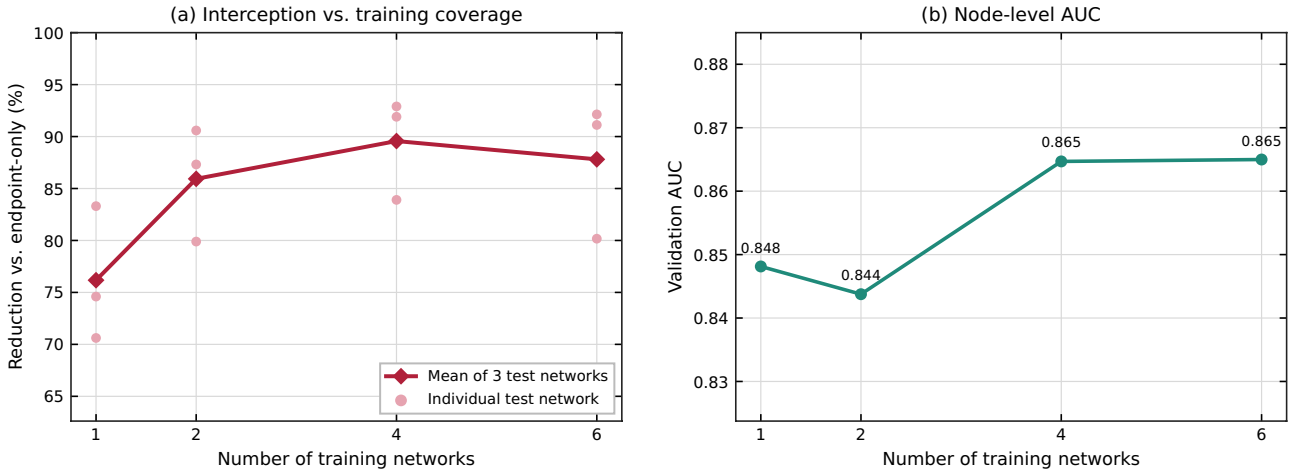



**Fig. 9** Generalisation across training-network coverage. (**a**) Mean interception reduction on three always-fresh test networks (line; points are the individual networks) rises from 76.2% with a single training network to 89.6% with four, then plateaus. (**b**) Validation AUC is noisier and non-monotonic, illustrating that node-level discrimination is an imperfect proxy for the operational outcome in (**a**).

(76.2% mean reduction across the three fresh test networks; 70.6/83.3/74.6% individually) and improves to 85.9% with two and 89.6% with four training networks, after which it plateaus (87.8% with six). Validation AUC is noisier and *not* monotonic in the number of training networks (0.848, 0.844, 0.865, 0.865), and its small dip at two networks coincides with a large gain in interception, underscoring the point already made in "Predicting the hidden infection front": node-level discrimination quality is an imperfect proxy for operational interception performance, and the latter is what should drive deployment decisions. The practical implication is encouraging: an organisation does not need to pool data from a large fleet of networks before the approach becomes useful, though, as with any learned model, broader training coverage adds a clear margin, up to about four networks.

## Robustness to a patient (synchronised-detonation) attacker

"Early interception sharply reduces encryption" to "Robustness to spread rate and detection delay" evaluate the standard timing model, in which each compromised host detonates independently after a short dwell giving the defender an early, informative signal. Real ransomware operators, however, are increasingly reported to delay encryption for an extended "land and expand" phase before triggering coordinated, near-simultaneous encryption across many hosts at once[3,4], precisely to deny defenders that early signal. We introduce an abstract *patient-attacker* timing model ("Patient-attacker (synchronised-detonation) propagation model") in which all currently compromised hosts detonate together at a trigger step $T_{\text{trig}}$, and evaluate every defence as $T_{\text{trig}}$ is swept from 4 to 20 steps, averaged over three held-out networks (10 campaigns each). Table 6 and Fig. 10 report the result, and it is, by design, a stress test rather than a favourable scenario for the proposed method.

**Table 6** Fraction of files encrypted under the patient-attacker (synchronised-detonation) timing model, by silent dwell before the synchronised strike ($T_{trig}$, in steps), averaged over three held-out networks × 10 campaigns. At short dwell the graph policies retain a clear advantage; as dwell grows all detonation-reactive defences, including the GAT, converge toward the no-defence outcome.

| Strategy | $T_{trig} = 4$ | $T_{trig} = 8$ | $T_{trig} = 14$ | $T_{trig} = 20$ |
|---|---|---|---|---|
| No defence | 0.744 | 0.929 | 0.985 | 0.995 |
| Endpoint-only | 0.449 | 0.735 | 0.947 | 0.989 |
| Degree-ranked | 0.302 | 0.755 | 0.953 | 0.985 |
| Vulnerability-ranked | 0.661 | 0.863 | 0.953 | 0.987 |
| Frontier | 0.442 | 0.813 | 0.951 | 0.986 |
| GCN | **0.259** | 0.749 | 0.953 | 0.986 |
| **GAT (proposed)** | 0.261 | 0.751 | 0.952 | 0.986 |

Significant values are in bold.

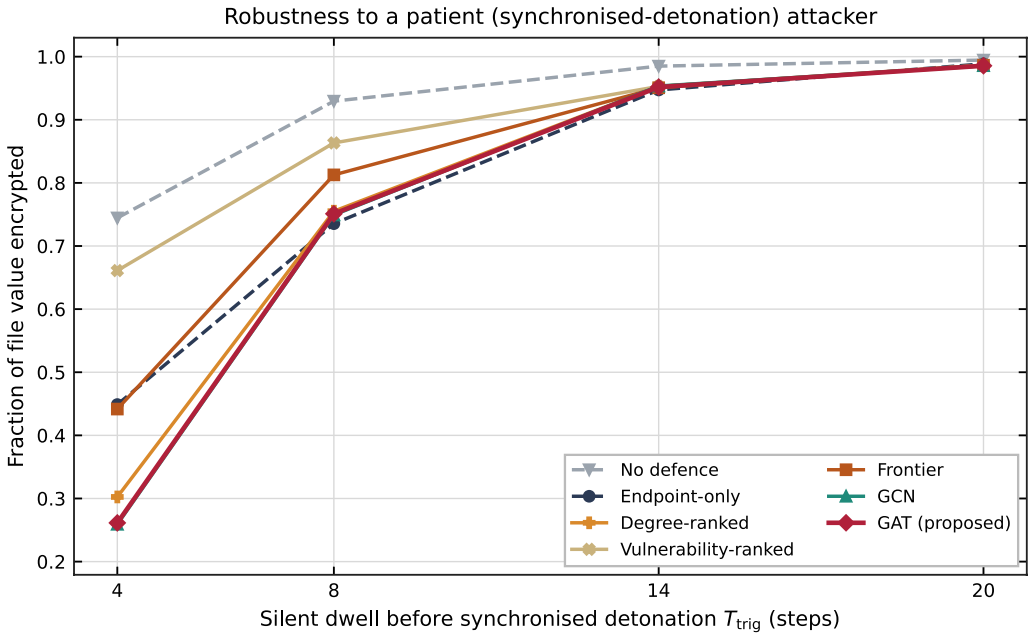



**Fig. 10** Robustness to a patient (synchronised-detonation) attacker. At short silent dwell the graph policies retain a clear advantage over heuristics; as the silent dwell before the synchronised strike grows, all detonation-reactive defences including the GAT converge toward the no-defence outcome, because the defender's only dynamic signal is withheld until the strike (Proposition 2).

At short silent dwell ($T_{trig} = 4$), the ordering of "Early interception sharply reduces encryption" is preserved: the graph policies achieve the lowest encrypted fractions (GAT 0.261, GCN 0.259), ahead of degree-ranked isolation (0.302) and far ahead of the frontier heuristic (0.442) and endpoint-only (0.449). As the silent dwell grows, however, every detonation-reactive defence's advantage erodes rapidly: by $T_{trig} = 8$ the GAT (0.751), GCN (0.749), degree-ranking (0.755), and even endpoint-only isolation (0.735) are nearly indistinguishable, and the frontier heuristic (0.813) is worse than endpoint-only; by $T_{trig} = 14$–20 *all* defences, including the proposed GAT, converge to within a few percentage points of the no-defence outcome (0.947–0.989 versus 0.985–0.995). This is the empirical counterpart of Proposition 2: once enough hosts are silently compromised before any detonation is visible, the GAT has no dynamic signal to act on during the critical window, its ranking degenerates toward the static-feature ordering shared with the simpler heuristics, and by the time the synchronised strike occurs the majority of the network's file value is already behind hosts that will detonate simultaneously. We regard this as an important, honestly reported finding: the proposed method's large advantage in "Early interception sharply

reduces encryption" to "Robustness to spread rate and detection delay" is specific to attackers that produce an early, gradual detonation signal, and should not be read as a general guarantee against an adversary that deliberately withholds one.

## Adaptivity of the adversary: two evasion axes

A natural question is how the defence fares against an adversary that *adapts* to it rather than a fixed one. Our evaluation already probes adaptivity along two distinct axes, which we make explicit here. The first is *temporal* adaptivity: the patient attacker of "Robustness to a patient (synchronised-detonation) attacker" is precisely an adversary that adapts the timing of the very signal the defence depends on, withholding detonation to starve the GAT of dynamic input. Table 6 quantifies this end to end, and Proposition 2 bounds it: as the silent dwell $T_{\text{trig}}$ grows, the achievable advantage of any detonation-triggered policy over static-feature ranking tends to zero, and the measured gap between the GAT and the no-defence baseline closes from 0.48 at $T_{\text{trig}} = 4$ to 0.009 by $T_{\text{trig}} = 20$. This is a direct, quantitative characterisation of an adaptive attacker's effect, not a qualitative caveat.

The second is *spatial* adaptivity: an adversary that adapts *where* it breaches to maximise damage against the defence. The breach-location analysis of "Breach location and generalisation across network size" supplies this measurement. A naïve adversary that lands on a random workstation is contained well (87% mean reduction). Choosing a high-degree workstation hub does not help the adversary (87%), but deliberately breaching a server the rational choice against a containment defence cuts the GAT's advantage to a 71% reduction (Fig. 7a). Read as an adaptive-evasion result, the worst-case breach placement removes about a fifth of the defence's effectiveness relative to the nominal case, and it identifies the concrete asset class (servers) an adaptive attacker would target and that a defender should therefore harden independently. Table 7 consolidates both axes into a single worst-case-versus-nominal view.

We stop short of claiming robustness to a *jointly* optimal adversary that co-adapts breach placement, lateral-movement policy, and detonation timing against full knowledge of the GAT's feature set: constructing and training against such an adversary (e.g. by adversarial or game-theoretic optimisation of the attacker policy) is a substantial study in itself and is out of scope here. What we provide is a quantified account of two of the most operationally relevant single-axis adaptations, together with a proof (Proposition 2) that isolates the structural reason the temporal axis is fundamental rather than incidental, and an explicit statement that the appropriate response is architectural (defence in depth with detonation-independent signals), not merely a better-tuned detector.

## An ensemble of GAT and GCN

Because the GAT and GCN are trained independently and achieve comparable but non-identical node-level predictions (Table 3), we evaluate a simple ensemble[14] that averages their predicted probabilities before ranking. On the main 64-campaign sample (Table 4) the ensemble has the lowest mean of all non-oracle defences (0.051, a 91% reduction, versus 0.063 for the GCN and 0.092 for the GAT) and the smallest standard deviation (0.072). To

**Table 7** Adaptive-adversary summary. Each row is an axis along which the attacker can adapt to the defence; "nominal" is the non-adaptive setting and "adapted" is the attacker's most effective choice along that axis in our experiments. Values are mean encrypted-fraction reduction of the proposed GAT policy relative to endpoint-only (spatial axis) or the residual GAT-vs-no-defence gap (temporal axis). Both axes show a substantial, quantified erosion, motivating the detonation-independent complementary defences discussed in "Discussion".

| Adaptivity axis | Nominal | Adapted (attacker's best) |
|---|---|---|
| Spatial (breach placement, "Breach location and generalisation across network size") | 87% reduction (random workstation) | 71% reduction (server) |
| Temporal (detonation timing, "Robustness to a patient (synchronised-detonation) attacker") | 0.48 gap ($T_{\text{trig}} = 4$) | 0.009 gap ($T_{\text{trig}} = 20$) |

check that this is not an artefact of one campaign sample, we repeated the comparison on an independent sample (the same four held-out networks with 12 fresh campaigns each, seed offset 500000; Table 8). The ordering is reproduced: the ensemble again has the lowest mean (0.059, versus 0.065 for the GCN and 0.088 for the GAT), and its standard deviation (0.083) matches the GCN's (0.083) and is well below the GAT's (0.114). We report this as a consistent but modest effect: ensembling is a low-cost addition (no retraining is required, only combining two already-trained models' outputs) whose gain over the GCN alone is small, and it is not a substitute for the much larger gain of the graph-based approach itself ("Early interception sharply reduces encryption").

### Statistical robustness of the comparison

Because every defence faces the same 64 campaigns (Table 4), we compare defences with paired tests: for each pair we report the mean difference in encrypted fraction with a 95% bootstrap confidence interval (10,000 resamples of campaigns) and a two-sided Wilcoxon signed-rank test. The GAT's advantage over endpoint-only detection is large and unambiguous (mean difference 0.505, 95% CI [0.435, 0.571], $p < 10^{-6}$; the GAT is better in 51 of 64 campaigns and tied in 12). It is also significant against the strongest heuristics: frontier isolation (0.161 [0.119, 0.204], $p < 10^{-6}$) and degree-ranked isolation (0.061 [0.039, 0.084], $p = 5.6 \times 10^{-6}$; better in 48 of 64 campaigns). The GAT's advantage over the frontier heuristic is not confined to the tail: their medians are 0.013 and 0.212. The comparison with the GCN goes the other way: the GCN's mean is lower by 0.029 (95% CI [0.015, 0.045], $p = 0.024$), with the GCN better in 26 campaigns, the GAT in 23, and 15 ties. This difference is small relative to the gap between either graph model and any heuristic, but it is statistically detectable, and we therefore do not claim that attention improves interception over graph convolution in this setting. We caution, as in "Early interception sharply reduces encryption", that the means of the graph-based policies are pulled upward by a right-skewed minority of hard campaigns, chiefly server breaches ("Breach location and generalisation across network size"), so the mean-based reduction is most representative of aggregate organisational risk (a few very bad incidents dominate total loss) and the median of the typical incident; we report both. The training-coverage and patient-attacker findings ("Generalisation across the number of training networks" to "Robustness to a patient (synchronised-detonation) attacker") are corroborated by trends across, respectively, four training-set sizes and four silent-dwell settings, rather than resting on a single comparison.

## Discussion

Table 9 synthesises the paper's comparative findings before we discuss their implications.

The results support a simple but consequential shift in perspective: ransomware defence should model and intercept *propagation*, not merely react to encryption. Endpoint-only detection, by construction one step behind the encryption it observes, leaves the majority of files encrypted in our experiments because the silent footholds seeded before detection continue unchecked. Casting the network as a dynamic knowledge graph and predicting the hidden infection front from the visible encryption pattern allows a proactive policy to sever lateral-movement

**Table 8** GAT, GCN, and an averaging ensemble, evaluated together on an independent sample (4 held-out networks × 12 campaigns = 48 paired campaigns; endpoint-only isolation gives a mean of 0.639 on this sample). These numbers differ slightly from the 64-campaign sample of Table 4 and should be compared only within this table. The ensemble has the lowest mean, and the lowest standard deviation jointly with the GCN.

| Method | Mean | Median | Std. dev. | Reduction vs. endpoint |
|---|---|---|---|---|
| GAT | 0.088 | 0.006 | 0.114 | 86% |
| GCN | 0.065 | 0.018 | **0.083** | 90% |
| Ensemble (avg. probability) | **0.059** | 0.006 | **0.083** | 91% |

Significant values are in bold.

**Table 9** Synthesis of comparative findings. "Standard timing" refers to the per-host dwell model of "Predicting the hidden infection front" to "Generalisation across the number of training networks"; "patient attacker" refers to the synchronised-detonation model of "Robustness to a patient (synchronised-detonation) attacker".

| Property | Best method | Evidence |
|---|---|---|
| Mean interception, standard timing | Ensemble > GCN > GAT (≫ heuristics) | Table 4 (91% / 89% / 85% reduction) |
| Typical-case (median) interception | Graph policies (≫ heuristics) | Table 4 (GAT 0.013 vs. frontier 0.212) |
| Node-level AUC | GAT ≈ GCN > pressure heuristic | Table 3 (0.885 / 0.882 / 0.870) |
| Precision at the top of the ranking | Pressure heuristic ≈ GCN > GAT | Table 3 (P@5%: 0.44 / 0.44 / 0.34) |
| Budget efficiency | GCN ≳ GAT (≫ frontier) | Figure 5 |
| Robustness to spread rate & dwell | GCN, then GAT | Figure 6 |
| Breach location | Server breaches hardest for all | Figure 7a (GAT 71% vs. 87%) |
| Generalisation across network size | GCN (declines less) | Figure 7b (GAT 93% → 78%) |
| Generalisation across training coverage | GAT useful from one network | Table 5 (76.2% → 89.6%) |
| Short-dwell patient attacker | GAT ≈ GCN | Table 6 ($T_{\text{trig}} = 4$) |
| Long-dwell patient attacker | none (all converge) | Table 6 ($T_{\text{trig}} \geq 14$) |
| Outcome variance | Ensemble ≈ GCN | Tables 4 and 8 |
| Interpretability | GAT (attention weights) | Figure 8 |

paths early, reducing mean encrypted file value by 85–91% (a six- to twelve-fold reduction) relative to endpoint-only detection and approaching the performance of an omniscient defender. This holds under the standard timing model across a wide range of spread rates and dwell times, with smaller but still substantial gains for server breaches and larger networks, and importantly for practical adoption even when the training data covers only one or two enterprise networks.

A central and deliberately reported nuance is that the advantage of the graph-based approach lies less in any single architecture than in the graph formulation and the containment-aware ranking together. On the node-level prediction task, the GAT and a GCN ablation have nearly identical AUC, and even a non-graph pressure heuristic predicts moderately well; yet in interception the graph policies reduce mean encryption by 85–89% while the best heuristic (degree-ranked) reaches 74%. The reason is that effective interception is not node classification but *high-impact targeting*: isolating the few silently compromised hosts whose connectivity makes them the engines of spread. The graph policies achieve this by combining predicted infection with spread capacity over the network structure, which a one-hop heuristic cannot. We retain the GAT as our primary model because its attention coefficients indicate which incoming lateral-movement edges drive each host's predicted risk, which supports the auditable risk map of Fig. 8. We do not, however, find that attention improves interception: the GCN is slightly but significantly better ("Statistical robustness of the comparison"), and averaging the two ("An ensemble of GAT and GCN") is better still at negligible extra cost. Practitioners who do not need edge-level explanations can therefore prefer the GCN or the ensemble without loss.

The second and, in our view, more consequential finding of this extended study is the patient-attacker result of "Robustness to a patient (synchronised-detonation) attacker". It demonstrates, formally (Proposition 2) and empirically (Table 6), that *any* defence restricted to the visible-detonation signal including the proposed GAT degenerates toward static-attribute prioritisation, and hence toward the performance of simple heuristics, once an attacker withholds detonation for long enough. This is not a flaw specific to the GAT architecture; it is a structural property of detonation-triggered defence as a class, and it means that the strong results of "Early interception sharply reduces encryption" to "Generalisation across the number of training networks" should be understood as applying to attackers that produce an early, gradual signal which is realistic for many ransomware campaigns, but not all of them. The practical implication is that graph-based interception of the kind proposed here is best deployed as one layer in a defence-in-depth posture, *alongside* mechanisms that do not depend on detonation visibility at all network segmentation and zero-trust access policies that bound lateral movement regardless of detection, and deception techniques (honeypots, honeytokens, canary files) that can generate an early, low-cost

*detonation-independent* signal even from a patient attacker, restoring exactly the dynamic information that Proposition 2 shows the GAT otherwise lacks during a silent phase.

### Operational cost asymmetry and tail risk

The mean/median divergence noted in "Statistical robustness of the comparison" has a direct organisational reading. Most simulated incidents under the proposed defence are contained almost completely (median encrypted fraction 0.013), but a minority disproportionately the server-breach scenarios of "Breach location and generalisation across network size" are contained far less well, and it is these that dominate the *mean*, and hence aggregate expected loss across many incidents over time. This is the same statistical structure that underlies cyber-insurance and operational-risk practice more broadly: typical-case performance and tail-case (worst-case) performance are different quantities that warrant different decisions. In our experiments the graph policies improve on the heuristics on both counts ("Statistical robustness of the comparison"), but the tail is where their remaining losses concentrate, so a defender optimising for aggregate or worst-case exposure arguably the more relevant objective for a security investment decision should weight the mean reduction more heavily and should specifically prioritise the hardening of server assets identified in "Breach location and generalisation across network size" as the locus of the remaining tail risk. We surface both quantities throughout the paper, and the breach-location breakdown specifically, so that this distinction is available to the reader rather than obscured by a single summary statistic; a full economic treatment (e.g. expected-loss modelling with explicit incident-cost distributions) is beyond our scope but is a natural extension building directly on the per-condition data we report.

### Outlook

All networks, authentication-derived edge weights, and campaigns in this study are synthetic, so validating the approach on de-identified enterprise topologies and real authentication logs is the most important next step. Beyond that, the framework extends naturally to richer graphs (identity and credential graphs, process- and flow-level telemetry), to temporal graph models that exploit the order of authentication events and might partially recover signal even under a patient attacker (e.g. from anomalous but non-encrypting lateral movement, rather than only from detonation), and to joint optimisation of detection and isolation under explicit operational-cost constraints. The patient-attacker finding specifically motivates combining the proposed approach with detonation-independent signals deception assets and behavioural lateral- movement anomaly detection so that the defender retains an early dynamic signal even when an adversary deliberately withholds visible encryption; formalising and evaluating such a hybrid defence is a natural next study.

Concretely, the interpretable risk map of "Interpretability" is directly usable by a security operations centre (SOC) rather than only by an offline evaluation pipeline. A natural integration is as a ranked, continuously updated worklist feeding a security orchestration, automation and response (SOAR) platform: the top-ranked hosts by predicted risk times spread capacity ("The isolation policy and its structural properties") are surfaced to an analyst with the contributing dynamic features (incoming detonation pressure, hop-distance to the nearest detonation, two-hop pressure) shown alongside the score, so the recommendation is auditable rather than a bare number. Because Proposition 1 guarantees that isolating more hosts can only help containment, a SOC operating under time pressure can act on a partial prefix of the ranked list as analyst capacity allows, with a graceful degradation in outcome rather than an all-or-nothing decision; the budget sweep of "Effect of the response budget" directly quantifies this trade-off and can inform staffing or automation thresholds (e.g. auto-isolating only the top few hosts above a score threshold, with the remainder queued for analyst review). The patient-attacker result motivates a complementary alerting rule: because Proposition 2 shows the GAT's dynamic ranking is uninformative before any detonation is observed, a SOC should not treat the absence of GAT-driven alerts as evidence of safety, and should pair the proposed system with independent, detonation-*independent* triggers (deception-asset access, anomalous credential use) precisely to avoid over-relying on a signal that a sufficiently patient adversary

can withhold. More broadly, the result that a contagion's hidden front can be inferred from sparse visible signals and graph structure, and then intercepted, is not specific to ransomware: it applies to worm outbreaks, fraud propagation, and other network-borne threats, with the important caveat, demonstrated here, that any such defence should be explicitly stress-tested against an adversary that can adapt the timing of the very signal the defence relies on.

## Conclusion

We presented a graph-based approach to early ransomware interception that models enterprise networks as dynamic knowledge graphs and uses a graph attention network to predict hidden infection fronts from visible encryption signals, enabling proactive isolation before encryption occurs. In a controlled, MITRE ATT&CK-structured simulation that contains no exploit code, payload, or operational attack technique, the approach reduces mean encrypted file value by 85% relative to endpoint-only detection, is robust across a wide range of spread rates and dwell times, retains a substantial but smaller advantage for server breaches and larger networks, and as shown for the first time in this extended study obtains most of its advantage when trained on a single enterprise network. We also introduced and evaluated an abstract patient-attacker model that withholds visible detonation, and showed both formally and empirically that this exposes a genuine, general limitation of detonation-triggered defence as a class: the proposed method's large advantage is concentrated in the realistic but not universal regime of early, gradual detonation signals, and should be complemented by detonation- independent defences when facing a sufficiently patient adversary. We reported these findings, including where the method does not win: a GCN baseline slightly outperforms the GAT on interception, and an ensemble of the two performs best, so the benefit comes from the graph formulation and the containment-aware policy rather than from attention itself. For organisations seeking to move beyond reactive, encryption-triggered response, graph- based early interception is a principled and practical addition to a layered defence, with its scope and limits now characterised explicitly.

The training-coverage result ("Generalisation across the number of training networks") carries a practical implication for how this approach might be adopted across organisations. Because most of the interception performance is obtained with as few as one or two training networks, an individual organisation does not need a large internal fleet, or access to other organisations' raw network topologies, to obtain a useful model; this also opens the door to *federated* training, in which several organisations collaboratively improve a shared GAT by exchanging only model updates not network graphs or authentication logs computed locally on each participant's own simulated or historical campaigns, analogous to federated learning approaches used elsewhere in network security. Such a deployment would let the broader sector benefit from training-network diversity ("Generalisation across the number of training networks" shows interception reduction improving from one to four training networks before it plateaus) without any participant exposing sensitive topology or authentication data, and is a natural next step for translating this study's findings into a multi-organisation defensive capability.

## Appendix A: Additional sensitivity results

This appendix tabulates exact values underlying Figs. 5 and 6, for readers who wish to inspect the numbers directly. All three sweeps reuse the 64 paired campaigns of Table 4, so the canonical column of each table ($k = 8$, $\beta = 0.6$, $\tau = 2$) reproduces the corresponding entries of Table 4.

See Tables 10, 11 and 12.

**Table 10** Encrypted-file fraction versus per-step isolation budget $k$ (see "Effect of the response budget" and Fig. 5).

| Budget $k$ | 2 | 4 | 6 | 8 | 10 | 12 |
|---|---|---|---|---|---|---|
| Endpoint-only (constant) | 0.597 | 0.597 | 0.597 | 0.597 | 0.597 | 0.597 |

**Table 10** Encrypted-file fraction versus per-step isolation budget $k$ (see "Effect of the response budget" and Fig. 5).

| Budget $k$ | 2 | 4 | 6 | 8 | 10 | 12 |
|---|---|---|---|---|---|---|
| Frontier | 0.630 | 0.418 | 0.334 | 0.253 | 0.204 | 0.170 |
| GCN | 0.515 | 0.217 | 0.108 | 0.063 | 0.037 | 0.024 |
| GAT | 0.508 | 0.222 | 0.139 | 0.092 | 0.058 | 0.042 |

**Table 11** Encrypted-file fraction versus lateral-movement aggressiveness $\beta$ (see "Robustness to spread rate and detection delay" and Fig. 6a).

| Spread $\beta$ | 0.4 | 0.5 | 0.6 | 0.7 | 0.8 |
|---|---|---|---|---|---|
| Endpoint-only | 0.372 | 0.528 | 0.597 | 0.670 | 0.736 |
| Frontier | 0.088 | 0.172 | 0.253 | 0.297 | 0.363 |
| GCN | 0.022 | 0.038 | 0.063 | 0.082 | 0.114 |
| GAT | 0.022 | 0.053 | 0.092 | 0.122 | 0.170 |

**Table 12** Encrypted-file fraction versus per-host dwell $\tau$, standard timing model (see "Robustness to spread rate and detection delay" and Fig. 6b).

| Dwell $\tau$ (steps) | 1 | 2 | 3 | 4 |
|---|---|---|---|---|
| Endpoint-only | 0.215 | 0.597 | 0.804 | 0.872 |
| Frontier | 0.037 | 0.253 | 0.438 | 0.528 |
| GCN | 0.018 | 0.063 | 0.128 | 0.191 |
| GAT | 0.008 | 0.092 | 0.207 | 0.297 |

## Appendix B: Network-generation parameters

For full reproducibility we list the exact generative parameters of the enterprise network model ("Enterprise network model"). The number of subnets is $\lceil N/60 \rceil$ (5 for the canonical $N = 300$). Each host is independently assigned a subnet uniformly at random. Server flag: Bernoulli with $p = 0.08$. Vulnerability: $v \sim \mathrm{Beta}(2.0, 3.0)$, reduced by 0.10 for servers, clipped to [0.02, 0.99]. Privilege: $\pi \sim \mathrm{Beta}(1.5, 6.0)$, increased by 0.4 for servers, clipped to [0, 1]. File value: $\mathrm{round}(\mathrm{LogNormal}(3.0, 0.8) \times (1 + 8\,\mathrm{is_server}))$. Edges: each host forms 3–7 intra-subnet peer links (weight $\sim \mathcal{U}(0.25, 0.75)$), 1–3 links to randomly chosen servers (weight $\sim \mathcal{U}(0.4, 0.85)$), and each server additionally forms 15–34 links to randomly chosen hosts network-wide (weight $\sim \mathcal{U}(0.3, 0.8)$), representing administrative/push-channel reach; duplicate directed pairs are resolved by taking the maximum weight.

## Appendix C: Reproducibility checklist

Table 13 collects, in one place, the exact settings needed to regenerate every reported number; all are also stated in context in "Methods" and in the accompanying code's seed lists.

**Table 13** Reproducibility checklist: exact settings by experiment.

| Component | Setting |
|---|---|
| Network size | $N = 300$ (canonical); $N \in \{150, 300, 450\}$ for the size-generalisation test ("Breach location and generalisation across network size") |
| GAT/GCN architecture | 2 layers, hidden width $H = 32$ (main models), $H = 24$ (training-coverage sweep, "Generalisation across the number of training networks"), 12-dimensional input features |
| Optimiser | Adam, learning rate $5 \times 10^{-3}$, weight decay $10^{-5}$[15] |
| Training epochs | 20 (main models); 10 (training-coverage sweep) |
| Training/validation networks | 6 train / 2 validation (main models, seeds 10–17); 1, 2, 4, 6 train / 2 fixed validation ("Generalisation across the number of training networks", seeds 10–15 subset + 18, 19) |
| Interception test networks | 4 networks, seeds 20–23 (Table 4); seeds 25–27 ("Generalisation across the number of training networks"); seeds 30–32 ("Robustness to a patient (synchronised-detonation) attacker", patient attacker) |

**Table 13** Reproducibility checklist: exact settings by experiment.

| Component | Setting |
|---|---|
| Campaign parameters (standard) | spread $\beta = 0.6$, dwell $\tau = 2$, max steps 40, isolation budget $k = 8$ (canonical) |
| Campaign parameters (patient attacker) | spread $\beta = 0.6$, trigger step $T_{\text{trig}} \in \{4, 8, 14, 20\}$, 6 post-trigger steps |
| Campaigns per network | 16 (Table 4 and all sensitivity sweeps of "Effect of the response budget" to "Breach location and generalisation across network size", which reuse the same 64 paired campaigns); 12 (training data per network, and the independent ensemble replication of "An ensemble of GAT and GCN", seed offset 500000); 10 ("Generalisation across the number of training networks" to "Robustness to a patient (synchronised-detonation) attacker") |
| Random-number protocol | common random numbers across all defences within a paired campaign (same breach host and propagation seed) |
| Gradient verification | finite-difference check, max. error $2 \times 10^{-10}$ |

**Author contributions** N.A.K prepared the whole article including conceptualization, methodology, results and writing.

**Data availability** No external or third-party datasets were used in this study. All enterprise networks, authenticationderived edge weights, and simulated campaigns analysed here are synthetic and are generated deterministically by the deposited code (see Code availability) from the random seeds recorded with each experiment, so every reported number, table, and figure can be regenerated exactly.

**Code availability** All custom code and algorithms used to generate the results of this study are openly available in a Github repository at https://github.com/alkhater11/Graph-Based-Ransomware, released under the MIT licence. The repository c ontains the abstract graph-contagion simulator (both the standard per-host-dwell and the patient synchronised-detonation timing models), the synthetic enterprise-network generator, the from-scratch reverse-mode automatic-differentiation engine with its finite-difference gradient check, the graph attention network and graph convolutional network implementations, the containment-aware isolation policy (Algorithm 1) and all baseline defence strategies, and the experiment and figure-generation scripts.

## Declarations

**Competing interests** The authors declare no competing interests.

**Open Access** This article is licensed under a Creative Commons Attribution-NonCommercial-NoDerivatives 4.0 International License, which permits any non-commercial use, sharing, distribution and reproduction in any medium or format, as long as you give appropriate credit to the original author(s) and the source, provide a link to the Creative Commons licence, and indicate if you modified the licensed material. You do not have permission under this licence to share adapted material derived from this article or parts of it. The images or other third party material in this article are included in the article's Creative Commons licence, unless indicated otherwise in a credit line to the material. If material is not included in the article's Creative Commons licence and your intended use is not permitted by statutory regulation or exceeds the permitted use, you will need to obtain permission directly from the copyright holder. To view a copy of this licence, visit http://creativecommons.org/licenses/by-nc-nd/4.0/.

## References

1. Strom, B.E., Applebaum, A., Miller, D.P., Nickels, K.C., Pennington, A.G. & Thomas, C.B. MITRE ATT&CK: Design and philosophy. In *MITRE Technical Report* (2018).
2. Cybersecurity and Infrastructure Security Agency. # StopRansomware Guide. In *CISA/MS-ISAC Joint Guide* (2023).
3. Al-rimy, B. A. S., Maarof, M. A. & Shaid, S. Z. M. Ransomware threat success factors, taxonomy, and countermeasures: A survey and research directions. *Comput. Secur.* **74**, 144–166 (2018).
4. Berrueta, E., Morato, D., Magaña, E. & Izal, M. A survey on detection techniques for cryptographic ransomware. *IEEE Access* **7**, 144925–144944 (2019).
5. Bohara, A., Noureddine, M. A., Fawaz, A. & Sanders, W. H. An unsupervised multi-detector approach for identifying malicious lateral movement. In *IEEE Symposium on Reliable Distributed Systems (SRDS)*. 224–233 (2017).
6. Kephart, J. O. & White, S. R. Directed-graph epidemiological models of computer viruses. In *IEEE Symposium on Security and Privacy*. 343–359 (1991).

7. Pastor-Satorras, R., Castellano, C., Van Mieghem, P. & Vespignani, A. Epidemic processes in complex networks. *Rev. Mod. Phys.***87**(3), 925–979 (2015).
8. Newman, M. E. J. Spread of epidemic disease on networks. *Phys. Rev. E* **66**(1), 016128 (2002).
9. Zhou, J. et al. Graph neural networks: A review of methods and applications. *AI Open* **1**, 57–81 (2020).
10. Hossain, M. N. et al. SLEUTH: Real-time attack scenario reconstruction from COTS audit data. In *USENIX Security Symposium*. 487–504 (2017).
11. Hamilton, W. L., Ying, R. & Leskovec, J. Inductive Representation Learning on Large Graphs (NeurIPS, 2017).
12. Veličković, P. et al. Graph attention networks. In *International Conference on Learning Representations (ICLR)* (2018).
13. Kipf, T.N. & Welling, M. Semi-supervised classification with graph convolutional networks. In *ICLR* (2017).
14. Dietterich, T. G. Ensemble methods in machine learning. In *International Workshop on Multiple Classifier Systems*. 1–15 (2000).
15. Kingma, D.P. & Ba, J. Adam: A method for stochastic optimization. In *ICLR* (2015)

**Publisher's note** Springer Nature remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.

## Authors and Affiliations

### Noora Al Khater[1]

✉ Noora Al Khater
nralkhater@uhb.edu.sa

[1] Department of Computer Science and Engineering, College of Computer Science and Engineering, University of Hafr Al Batin, 39524 Hafr Al Batin, Saudi Arabia